

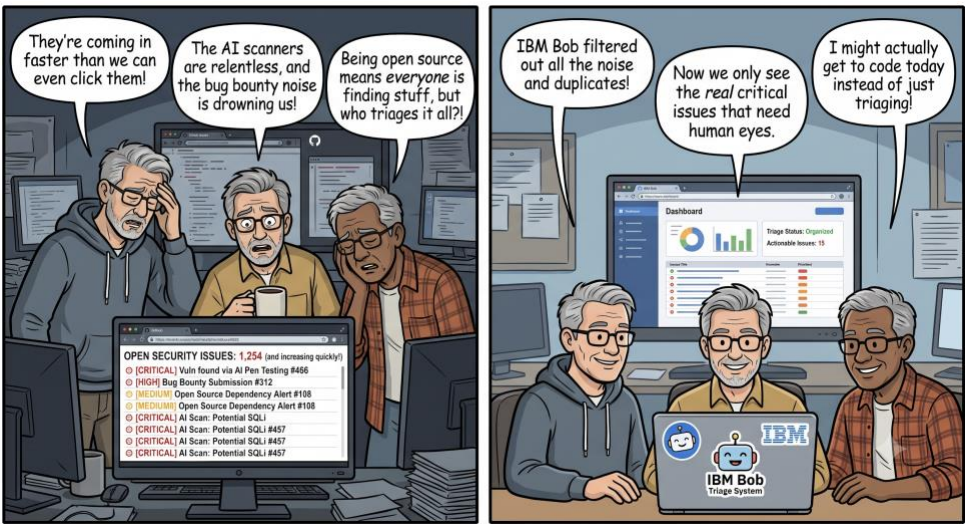
BobSentry

Semi-autonomous AI Security Triage for Client/Server Applications

WatsonX Challenge · July 2026

The Problem

Security teams triaging security vulnerabilities face a bottleneck – too few engineers for too many potential security vulnerabilities, especially with AI enhanced attacks on the increase. Missing one of these could be catastrophic to a business.



Time	3–5 hours per security github issue - reading the issue, spinning up a sandbox, writing exploit scripts, and classifying the result manually. Not to mention the experience required by the team member to know how to do this.
Repeat	No artifact reuse - each engineer starts from scratch even when the attack class was seen last week.
Risk	Inconsistent guardrails - real credentials, live endpoints, and persistent containers create compliance and data-leak exposure.

The Solution - BobSentry

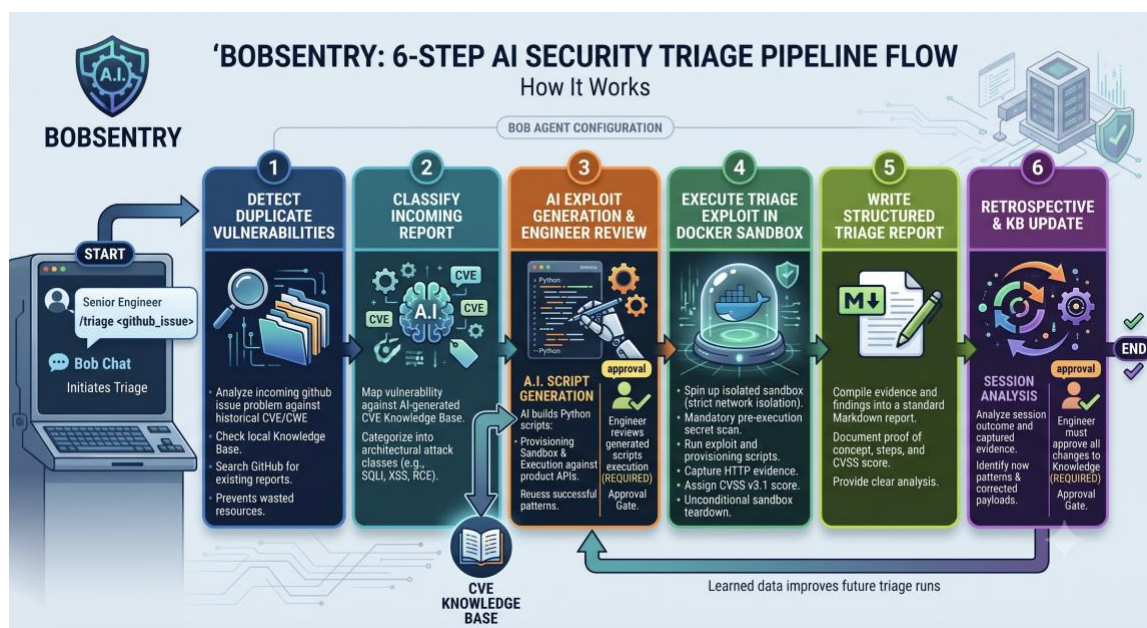
BobSentry converts a raw GitHub issue into a structured verdict - **confirmed** / **patch-verified** / **escalated** / **false-positive** - with reproducible scripts, a live sandbox execution log, CVSS v3.1 score, logs and proof for compliance and a detailed report, all without touching production systems. A single slash command does everything – `/triage <github_issue_number>`

How IBM Bob Powered This:

Bob Capability	How BobSentry Uses It
Custom Modes	Sentry mode loads guardrails, CVE knowledge base, and multi-model routing automatically on activation.
Skills (CVE Analyzer)	6-step pattern engine scores the issue against trained CVE profiles and 20-class vulnerability matrix; outputs threat JSON.

Slash Commands	/triage drives a 6-step pipeline across Plan → Code → Agent modes without manual orchestration.
Multi-Mode Orchestration	Plan mode produces a 4-stage triage plan (awaits approval); Code mode generates exploit scripts (awaits review); Agent mode runs sandbox, captures logs, tears it all down.
Skills (Env Manager)	Declarative Podman/Docker sandbox lifecycle — spin-up, healthcheck, teardown — all within the triage session.
Artifact Accumulation	Each session writes context.json + scripts to an attack-class folder; future triages read prior artifacts as scaffolding, progressively reducing script iterations.

6-Step Triage Pipeline



Productivity Impact - 5 Confirmed Triage Sessions (metrics-summary.md)

~18 min	~3 hrs	16.1 hrs	94%
Avg triage time (Bob-Sentry)	Avg manual baseline	Total time saved (5 issues)	Time saving per issue

All 5 issues tested were MEDIUM severity or above - including one BLOCKER (CVSS 9.1) achieving full realm takeover via a single Admin API call. Two FGAP sub-variants (#50983, #50981) were confirmed in a single session using prior-session artifacts as scaffolding, demonstrating the compound learning effect as the knowledge base grows.

Portability Demonstrated

The same pipeline was applied to **Pac4j** (SAML/Spring Boot) and **Quarkus OIDC** - projects with different languages, protocols, and architectures - with **zero changes to security guardrails** and only minimal adaptation to setup scripts. Any HTTP-accessible auth project that runs in Docker is a candidate.

Design & Usability

Zero config	No env vars, no YAML edits - open the repo in Bob, run the prompt to populate CVE history, switch to Security Sentry mode, run /triage. Prerequisites: Docker, gh CLI, Python 3.9+.
Human in the loop	Pipeline pauses at Step 3 (triage plan), Step 4 (script review), and Step 6 (KB update). No autonomous code runs without engineer sign-off.
Deterministic verdicts	HTTP response codes drive verdicts (200 = vulnerable, 401/403 = patched, 500 = escalate). No subjective interpretation; auditable by anyone.
Structured output	Every session produces a consistent Markdown report with CVSS v3.1 vector, severity label, executive summary, and reproduction steps. All data necessary to create a CVE report.
Safe by default	5 non-negotiable guardrails: localhost-only network, no real credentials, auto-cleanup, read-only GitHub access, pre-execution secret scan.
Staleness Markers	Staleness markers are used over time when a product version moves to a new major version, allowing agents to ignore information that is out of date.

Creativity & Innovation

Multi-mode orchestration	Bob's Plan / Code / Agent modes are used as specialised stages in a single pipeline — not just as a coding assistant. Plan writes the triage strategy; Code generates exploit scripts; Agent executes them. The modes act as a lightweight multi-agent system inside one tool.
Self-improving knowledge base	After each confirmed triage, a retrospective proposes targeted updates to keycloak-cve-history.md and admin-api-schemas.md. Over time the system gets faster and produces fewer script iterations per issue.
Portable methodology	Security guardrails, HTTP classification, and Docker isolation are fully project-agnostic. The pipeline transferred to Pac4j and Quarkus OIDC without rule changes — only setup scripts adapted.
CVE skill as threat oracle	The CVE Analyzer skill encodes IBM-style Winning Products thinking: it extracts a structured threat profile before any code runs, ensuring the triage plan is hypothesis-driven rather than exploratory.

Roadmap for Future Use

Horizon	Milestone	Impact
Now (done)	5 Keycloak CVEs triaged · Pac4j & Quarkus OIDC ported · 8-rule guardrail framework · HTML report UI	Proof of concept: 16 hrs saved in first run
Q3 2026	Project template library (Spring Security, ORY Hydra, Authentik) · Auto-detect framework from issue text · Slack/webhook notification on confirmed BLOCKER	3–5 projects supported out of the box
Q4 2026	CVE feed integration (NVD, OSV) - auto-open triage for new disclosures matching watched projects · Patch-verification re-triage triggered by PR merge	Continuous monitoring with zero manual intake
2027	Multi-team deployment: shared KB across security teams, cross-project pattern correlation, and CVSS trend dashboards for portfolio risk view	Enterprise-scale IAM security observability

BobSentry turns a 3-hour manual CVE triage into an 18-minute, reproducible, guardrail-enforced pipeline - using IBM Bob's custom modes, skills, and multi-mode orchestration as its engine. Every artifact it produces makes the next triage faster.